

BreadBank — Information Security Policy

Version 1.0 · Effective July 14, 2026 · Owner: abdisatar.venture@gmail.com

This document describes the security controls that are **operationalized** in the BreadBank application and its hosting environment. It is reviewed at least annually and whenever a material change is made to the system.

1. Scope & responsibility

BreadBank is a self-hosted personal-finance application that connects to users' financial institutions through **Plaid** and stores the resulting data. The application owner (contact above) is responsible for information security, including this policy, incident response, and access management.

2. Data classification

Class	Examples	Handling
Secret	Plaid access tokens, JWT signing key, DB credentials, encryption key	Encrypted at rest / stored only in environment, never in the repo
Sensitive	User transactions, balances, account details	Access-controlled, per-user isolation, encrypted transport
Credential	Passwords, security-question answers	Hashed with bcrypt (cost 12), never stored in plain text

3. Identity & access management

- **Authentication:** email + password. Passwords are bcrypt-hashed (cost 12). JWTs are signed server-side and expire; the server verifies every request.
- **Authorization / least privilege:** every query is scoped to the authenticated ``user_id``; one user can never read another's data.
- **Database:** the application connects using a dedicated least-privilege SQL account (``breadbank_user``), never the ``sa`` administrator account.
- **Host:** the app runs as a **non-root** user systemd service. Remote access to the host is over Tailscale (WireGuard) with device-level ACLs; SSH is key-based.

4. Encryption

- **In transit:** the application is served over HTTPS/TLS (TLS 1.2+), terminated by the reverse proxy / Tailscale HTTPS.
- **At rest:** Plaid access tokens are encrypted with **AES-256-GCM** (``backend/src/config/crypto.ts``). Credentials are bcrypt-hashed. Database storage resides on the host's protected volume.

5. Vulnerability & patch management

- Dependencies are scanned automatically on every push and weekly via GitHub Actions (`npm audit`) and **Dependabot** (see `.github/`).
- Container images are scanned with **Trivy** in CI.
- High/critical findings are triaged and patched promptly; dependencies are kept current.

6. Consent, retention & deletion

- Users must explicitly accept the Privacy Policy before an account is created; consent (timestamp + version) is recorded.
- Users can permanently delete their account and all associated data at any time from **Settings ! Delete account** which also disconnects linked Plaid items.
- See `docs/DATARETENTIONPOLICY.md`.

7. Logging & monitoring

- Application and service logs are captured by the host (`journalctl`).
- Errors are logged server-side; secrets are never logged.

8. Incident response

On suspected compromise: (1) rotate the JWT key, DB credentials, Plaid secret and encryption key; (2) invalidate sessions; (3) if bank data is implicated, revoke affected Plaid items and notify affected users; (4) record and remediate.

9. Review

This policy and the controls above are reviewed at least annually. Last review: July 14, 2026.